

Chapter 2 — Identity Assurance and Access Governance

1. Document control

- Identifier: HAL-BVI-02
- Version: 1.0
- Status: Final
- Effective date: 2026-07-27

2. Purpose

Govern identity assurance, authentication evidence, Authority and Permission dependencies, access review, lifecycle events, and identity quarantine.

3. Scope

This chapter applies to HAL environments, components, repositories, operators, providers, Trust Domains, evidence, and external exchanges within the stated control applicability.

4. Authority and source requirements

- Book I: Decisions 6, 27, 47-48
- Book II: Chapters 4-5, 23, 33
- Book III: Chapter 5
- Book IV: CMP-02, CMP-03, CMP-17, CMP-25
- Book X: Chapters 3-4, 8
- Book VIII governs verification and certification decisions; Book IX governs exact machine contracts.

5. Definitions and accountable roles

Book X terms retain their canonical meaning. Chapter roles: Identity Service Owner, Authority Service Owner, Access Administrator, Resource Owner, Security Operations, Independent Assessor.

6. Normative controls

VI-IAM-02-001 — Bind access to immutable identity

Every access decision MUST bind an authenticated immutable principal identity; names, locations, devices, network zones, or roles alone MUST NOT establish identity.

- Applicability: all access
- Responsible role: Identity Service Owner
- Enforcement: identity-context validation
- Required evidence: authentication record
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-IAM-02-002 — Independently evaluate Permission for every action

Successful authentication MUST NOT imply Permission; each protected operation MUST obtain a current Permission decision bounded by current Authority for the exact action, target, purpose, constraints, and time.

- Applicability: protected operations
- Responsible role: Authority Service Owner
- Enforcement: policy enforcement point
- Required evidence: Permission Decision Record
- Severity: Critical
- Exception authority: None
- Protection objective: Constrain HAL

VI-IAM-02-003 — Use risk-appropriate authentication

Authentication strength, freshness, liveness, device evidence, and step-up requirements **MUST** be proportionate to the protected consequence and environmental risk.

- Applicability: all sessions
- Responsible role: Identity Service Owner
- Enforcement: adaptive authentication policy
- Required evidence: authentication assurance record
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-IAM-02-004 — Review access continuously

Privileged, cross-domain, sensitive-data, and protected-state access **MUST** be reviewed on grant, material change, periodic cadence, incident, role change, and termination.

- Applicability: sensitive access
- Responsible role: Resource Owner
- Enforcement: access review workflow
- Required evidence: access review and disposition
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

VI-IAM-02-005 — Revoke promptly

Termination, compromise, expired delegation, quarantine, loss of need, or material risk increase **MUST** revoke or constrain affected sessions, tokens, permissions, and derived access without waiting for routine review.

- Applicability: access lifecycle events
- Responsible role: Access Administrator
- Enforcement: revocation automation
- Required evidence: revocation receipts
- Severity: Critical
- Exception authority: None
- Protection objective: Both

VI-IAM-02-006 — Quarantine without identity erasure

Identity quarantine MUST restrict new work and credentials, preserve forensic evidence, maintain historical attribution, and require independent release; an identity MUST NOT self-release.

- Applicability: suspect identities
- Responsible role: Security Operations
- Enforcement: quarantine state machine
- Required evidence: quarantine and release records
- Severity: Critical
- Exception authority: Security and Trust Executive
- Protection objective: Both

VI-IAM-02-007 — Prevent shared identities

Human operators MUST NOT share identities; service identities MUST be uniquely attributable to one workload identity and accountable owner.

- Applicability: all identities
- Responsible role: Identity Service Owner
- Enforcement: identity inventory scan
- Required evidence: identity registry
- Severity: High
- Exception authority: Security and Trust Executive
- Protection objective: Protect HAL

VI-IAM-02-008 — Minimize access

Permissions MUST be purpose-bound, least-privileged, scoped to resources and operations, and expire at the shortest practicable interval consistent with declared availability, integrity, and human-harm constraints.

- Applicability: all grants
- Responsible role: Resource Owner
- Enforcement: policy analysis and expiry
- Required evidence: grant record
- Severity: High
- Exception authority: Risk Steward
- Protection objective: Both

7. Required operating practices

Control Owners MUST maintain procedures, training, tools, dependencies, evidence paths, response actions, and succession coverage necessary to operate each applicable control.

8. Prohibited practices

- Treating trust, identity, credentials, compliance, or certification as Authority.
- Bypassing the authoritative component owner, Constitutional Kernel, Authority Service, Constitutional Firewall, or Evidence Service.
- Using undocumented, permanent, self-approved, or silently renewed exceptions.
- Replacing required evidence with assertion, dashboard color, ticket status, or unverified third-party claims.

9. Required evidence

Evidence MUST identify the control, target, version, environment, actor, time and confidence, source, method, outcome, exceptions, integrity, classification, retention, and linked incident or remediation.

10. Automated enforcement

Controls marked automated MUST deny, quarantine, expire, alert, or constrain according to the stated failure behavior. Automation MUST expose inputs, versions, decision logic, failures, and overrides.

11. Human review

A qualified reviewer MUST evaluate proportionality, constitutional restraint, privacy, trust assumptions, evidence sufficiency, conflicts of interest, and residual risk at the control's declared cadence and after material change.

12. Exceptions and failure consequences

Constitutional invariants are not waivable. Missing or expired exceptions MUST fail closed for protected actions or enter the safest evidence-preserving restricted state. Critical violations require incident evaluation and affected-assurance review.

13. Security, privacy, trust, and reliability considerations

Implementations MUST minimize sensitive evidence, preserve recoverability, constrain compromised components, keep trust separate from permission, and maintain auditable denial and recovery paths.

14. Verification method and metrics

Verify by catalog completeness checks, policy and configuration tests, adversarial negative cases, sampled evidence reconstruction, incident and recovery exercises, and independent review. Metrics MUST measure outcomes and control effectiveness rather than activity alone.

15. Traceability

- Book I: Decisions 6, 27, 47-48
- Book II: Chapters 4-5, 23, 33
- Book III: Chapter 5
- Book IV: CMP-02, CMP-03, CMP-17, CMP-25
- Book X: Chapters 3-4, 8

16. Examples and anti-patterns

Conforming example: the responsible role records a scoped decision, machine enforcement, minimized evidence, independent verification, expiry, and a tested failure path.

Anti-pattern: a team treats a credential with favorable Trust evidence, passing scan, active certificate, or urgent incident as Permission to bypass Authority or expand Treaty scope.

17. Review findings, Owner Review, and completion

Constitutional, architecture, enforceability, security, privacy, trust, reliability, usability, automation, duplication, and burden reviews found no unresolved material defect. No Owner Review item is required. Status: Complete.